

ANOMALY DETECTION IN ATM-GRADE SOFTWARE DEFINED NETWORKS

Philipp Lellek, Peter Leydold, Igor Vojnoski, Frequentis AG, Vienna, Austria

Dieter Eier, Frequentis USA, Columbia, MD

Abstract

The Federal Aviation Administration (FAA) and Air Navigation Service Providers (ANSPs) around the world are looking to share data and get interconnected with each other as well as data service consumers. This interconnectivity enables new functionality but also new attack vectors.

Today, agencies mostly rely on commercial security solutions providing adequate protection for commercial data services but have deficiencies when it comes to the Air Traffic Management (ATM) environment with its requirement for highest resilience, multi-level redundancies, and dynamic environment.

This paper introduces a novel approach to create an ATM-grade baseline integrating operational security events (OSE) and alerts (OSA) based on abnormal or malicious network traffic. An assured and trusted baseline is key to detecting atypical or malicious traffic. A testbed has been developed that models the regular ATM-grade IP-network behavior. The sample configuration uses open source stacks ElastiFlow, and SELKS to provide network flow data collection and visualization and demonstrate resilience against hacking attempts via unauthorized communication and protocols between nodes, unauthorized configuration changes via distribution of parameters to network nodes, as well as detection of malicious communication attempts from unauthorized devices on the network. A Software Defined Network (SDN) architecture is chosen as it features a programmable, efficient network configuration improving network performance and monitoring. The OpenFlow protocol is used to provide the control plane in the testbed. Data flows will be modeled as synchronous as well as asynchronous. Vulnerabilities are then identified, attack scenarios defined and applied to the testbed setup. The available SDN platform tools are then used to detect the anomalies. Sets of experiments are performed and the results compared and discussed.

Introduction

As systems get more interconnected threat levels are continuously increasing and thus cyber security is starting to take center stage at Air traffic management agencies worldwide. FAA, ICAO, Eurocontrol and SESAR all are now engaging in cyber security update initiatives.

Most activities center around the concept of *Protection*. As effective as protection concepts are, they are no longer sufficient. It is clear that protection layers are essential, but it is now also understood that breaches may not be completely preventable and attackers may break through the protection layers.

Detection mechanisms need to be implemented to augment the conventional protection layers. Interestingly, *Detection* is not at the core of most of the cyber security discussion in Air Traffic Management.

One of the main paradigms of SANS [1] is "Prevention is ideal but detection is a must". Being able to analyze the traffic within the environment to detect compromised systems greatly enhances the security of the system.

Most ANSPs use closed network solutions from vendors such as Cisco, Juniper, Nokia etc. As these systems allow only limited insight and greatly reduce the flexibility of the implementation due to the closed nature of their setups Open SDN approaches are preferred as they allow deeper insights and possibilities to control the network.

Many systems in the Air Traffic Management arena have been installed many years or even decades ago and agencies frequently opt for *IP-enabling* over *Replacement with modern cyber-protection built-in*. Connecting such legacy systems to the network creates dangerous threat cases and vulnerabilities.

Security Monitoring in ATM

Enterprise IT Security Monitoring Solutions aim to consolidate and correlate security logs,

information, and network data. Typically, this data is retrieved from multiple log sources (i.e. Antivirus, Firewalls, Proxies, other Network Devices, AD/LDAP Events, Host/OS Analytics, Application Logs). To enable better prioritization, modern approaches also incorporate vulnerability assessments of components to create a risk-based system overview.

These frameworks and approaches act as common architecture for organizations which deploy and operate Secure Operation Centers (SOC).

While these approaches are heavily utilized in Enterprise IT systems, they are difficult to impossible to apply to safety-critical, operational ATM systems.

Before commencing live operation ATM systems are typically subject to an extensive assurance process, safety assessments, and multiple testing phases. During runtime agencies tend to want to limit any operational changes of the assured baselines to avoid extensive regression testing if anything was to be changed. Common characteristics of such ATM systems are:

- Highly isolated system context
- Segmented networks
- Minimal change windows
- Mostly on-prem deployments only (i.e. no internet connectivity available)

These characteristics are often used as justification for mitigation of most common attack scenarios. They are regarded as an ATM system's primary line of defense. Major changes to these characteristics happen rarely during system lifecycles of ten to twenty years (or more!).

With ATM systems relying heavily on network isolation and segmentation integration into central IT monitoring solutions is not yet very common. ANSP's, and ATM agencies frequently cite challenges such as:

- Lack or immaturity of agency-wide enterprise architecture due to a vast majority of deployed systems being legacy
- OS / Applications allow local deployments only
- Additional monitoring software not permitted on safety assured systems and components

- Limited log management of IT components

As a result, common implementation issues are for instance,

- No antivirus solution with regular pattern updates installed on safety critical systems,
- Logs are disabled or not configured on components that process safety-critical data
- Depending on the result of the operational risk assessment, application allow listing
- Alternatively, an additional jump host with an Antivirus / EDR solution might be deployed.

This often results in isolated testing on a staging system and an almost unmonitored operational ATM system from an IT security perspective.

Because configuration and network changes of operational systems are highly controlled and are not allowed to impact negatively operational safety, passive monitoring became an obvious choice to close this monitoring gap. Some ANSPs have experimented with network traffic analysis, but usually focus on common IOCs/signatures only, without incorporating operational security events or alerts.

Given the isolated-system context it is assumed that common signatures will not trigger or alert during system operation in most cases, since (luckily) bad traffic patterns will not occur. This results in neglected usage by involved teams, since it is assumed that no real operational value can be derived from this approach.

In a laboratory experiment conducted in 2020 the authors have demonstrated an improved collaboration between operational and IT security teams, via a combined approach. By establishing operational relevant security events and alerts, it can be shown that added value can be generated for the operational team. This enables integration into existing processes like daily monitoring of operational events and logs. In addition, it delivers valuable insights into the system security state to the IT security team.

Practical Implementation

A combined detection approach of common IOCs, signatures, and operational relevant events (i.e. unplanned configuration change, abnormal management activities, malicious ED137 communication) is recommended for any practical implementation based on passive network analysis.

In the previously mentioned laboratory experiment passive profiling of a safety-critical ATM system's network communication as well as tailored alerting based on operational relevant security events and alerts has been demonstrated. Ensuring minimal safety impact and maximum backwards compatibility to operational / legacy systems, the primary goal was to use and rely on passive networking monitoring data only. Only Netflow and Full Packet Capture data was processed in the setup.

All necessary data were retrieved from the network layer 3 switch and the deployed Software defined networking (SDN) controllers.

The non-dynamic nature of the ATM-grade network, as well as the associated transporting traffic was modeled with standardized profiles allowing for the creation of a well-defined and accurate monitoring baseline. This allows for the tailoring of the monitoring solution to produce as few false positives as possible and results in actionable operational security events. The baseline is created by following fingerprinting of traffic patterns in the course of regular network during operation.

Experiment Setup

This section provides an overview of all components required and utilized during the experiment. The main components were based on an IP-based ATM voice and data communication system configured in a ED137 telephony setup [11].

ATM Equipment:

- Hardware
 - ATC Operator Position (ATC OP): Acting as phone client with direct communication capabilities
- Software
 - Network Management System (NMS) to carry out configuration changes

IT Equipment:

- Hardware
 - Cisco L3 Network Equipment: The L3 switch was configured with a dedicated interface to export the Netflow data as well as another dedicated interface as mirror port for full packet network capture.
 - Server Hardware
 - Client Workstations
- Software
 - VMWare ESXi: To fully virtualize required components of Netflow and network packet capture stack
 - Netflow stack: Based on ElastiFlow
 - Network packet capture stack: Based on SELKS, aka Suricata, ELK, Evebox, Arkime (formerly known as Moloch)
 - Tenable Nessus Professional: To carry out black box vulnerability scans.

Network Traffic Generation:

Monitoring data was captured during typical system load scenarios demonstrating alerting event capabilities events based on live network traffic analysis. Test scenarios were defined to ensure that the same events were reported and alerted on. Network traffic was also recorded via packet capture (PCAP) for offline analysis. Offline analysis of recorded data would allow for additional investigation. However, the goal of the experiment was to focus on real-time data analysis only.

ATM specific network traffic patterns were generated by initiating live telephony calls between the multiple ATC OP instances while carrying out configuration changes via the NMS as typically seen during normal operation. To test alerts based on rules from publicly available rulesets such as ET OPEN [12], defined attack scenarios and vulnerability scans were carried out to emulate adversary patterns.

Traffic Patterns:

Observed operational relevant protocols can be grouped into four categories.

- ATM Communication

- SIP, RTP
- Management and Monitoring
 - SSH, SNMP
- Supporting
 - NTP, DNS
- Other

Experiment Scenarios

Scenario A | Public Rule Feeds + Operational Traffic

This scenario was developed to showcase that relying on generic rules will not deliver value to the operational teams during regular system operations.

Voice communication and operational configuration changes were carried out as seen during live operation. The observed traffic did not trigger any of the used public rules, thus no alerts were raised as expected.

Scenario B | Public rule feeds + operational and malicious traffic

In the second scenario, we extended Scenario A and simulated malicious traffic as well. We selected initial access and lateral movement techniques based on the definition provided by MITRE ATT&CK® [2][3].

T1110	Brute Force
T1110.003	Password Spraying
T1595	Active Scanning
T1595.002	Vulnerability Scanning

The simulated attacks were carried out by executing baselined scripts and tools (i.e. NMAP, Tenable Nessus, Hydra). These tests triggered multiple of the public rules and successfully alerted on anomalous behavior tactics (reconnaissance, lateral movement, discovery).

Scenario C | Public Rules and Custom Operational Rules + Operational and Malicious Traffic

To fully showcase our operational security event monitoring approach, Scenario B was further extended to enable combined alerting. On top of Scenario B, tailored filters and rules were applied to trigger operational security events and alerts.

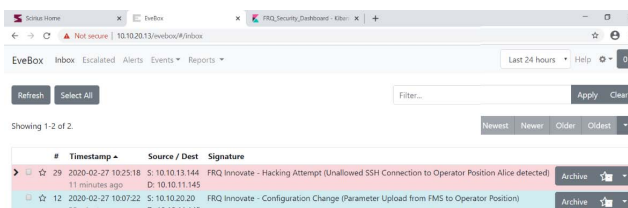


Figure 1. Example of Combined Alerting

The combined alerting example (Figure 1) is based on an operational security event and a common rule alert.

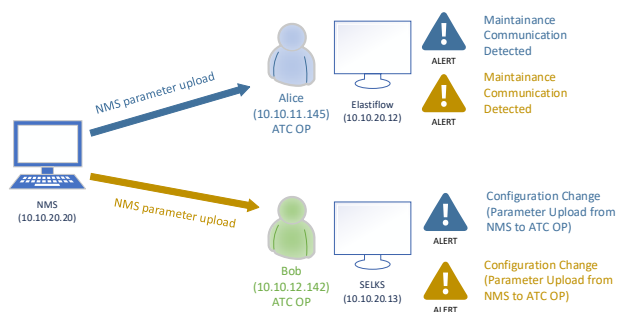


Figure 2. Detected Operational Security Event (Configuration Change)

This event demonstrates a potential use case for correlation with operational procedures (Figure 2). Based on this information, the operational team can verify if a configuration change was scheduled. Ideally, such operational security events or alerts would be further tailored to only trigger during certain monitoring windows. For example, a critical alert will be raised if no changes are planned, an informational event will be triggered if a change matches normal operational behavior (e.g. sector change multiple times a day).

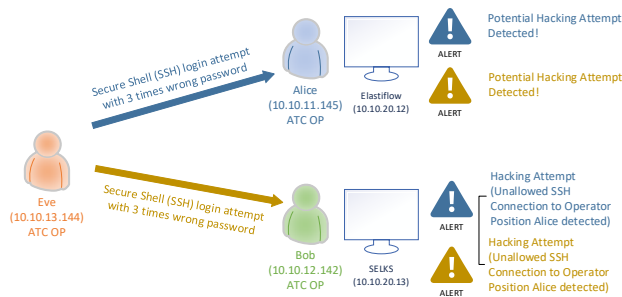


Figure 3. Detected Anomalous Behavior (Hacking Attempt)

To further visualize (Figure 3) the combined alerting approach, an alert based on common rulesets, was integrated as well. This was triggered by multiple failed login attempt on the management interface of an ATC OP.

The detection and alerting approach outlined in Scenario C is the preferred approach over Scenarios A and B and would add great value to both the operational as well as the IT security teams.

Onboarding into an Operational ATM System

The demonstrated approach utilized live network traffic during the experimental setup. The underlying solution stack also supports offline import of recorded network traffic (e.g. PCAP), the use of which can create additional value in allowing a rapid initial assessment of operational traffic patterns.

In addition, this approach would be well suited for incident response activities for suspicious activities. The operational traffic could be easily analyzed and mapped against known IOCs and rules to check if components show compromised behavior (e.g. connection to C&C servers or malicious servers).

Data Sources and Log Coverage in ATM Systems

Following the MITRE ATT&CK® knowledge base, common data sources for logging of security relevant information can be identified. An overview of the Top 10 data sources in IT systems based on prevalence was presented by Keith McCammon during MITRE ATT&CKcon 2 [7]. Log sources, sorted from highest to lowest coverage, are as follows:

- Process monitoring
- File monitoring
- Process command-line parameters
- API Monitoring
- Process use of network
- Packet Capture
- Windows Registry
- Authentication logs
- Network/Enclave netflow
- Windows Event logs

As discussed, logging of system events is still quite difficult in ATM systems since most systems are not managed like an IT system. This makes tasks like forwarding operating system logs challenging. Given the complexity, such changes are usually only carried out during a systems redesign, upgrade or replacement.

Based on the presented data [7], roughly 20% of events can be grouped into the network category. This might seem low, but even a 20% coverage would provide a massive improvement regarding operational insights compared to implementing nothing at all. The percentage rises even more by the unique environment of ATM systems. Reacting on a small, but well defined number of sources and events in an isolated network further enables better planning of operational responses.

Highlighting that these events can be retrieved with minimal impact to safety, this approach becomes a primary starting point for ANSPs in need of advanced security monitoring of their systems.

Difficulty of Validating ATM Threat Models

Security risk assessment and threat modeling can be complex on their own. Adding the ATM system's unique environment and context makes them even more challenging. But there is one common theme: Lack of validation. Adam Shostak defines the technical building blocks for threat modeling [4] as follows:

- What are we working on?
- What can go wrong?
- What are we going to do about it?

These questions might require effort to properly answer in an ATM system context. The most challenging part, though, is the missing and neglected forth question[5].

- Did we do a good job?

This question is the single most difficult to answer during an assessment or threat modelling session. And still, this fact is both good and bad at the same time. This stems from a lack of (public) regular critical security conferences taking place in ATM systems. This is of course a positive situation, but it still makes validation complicated, resulting in almost arbitrary prioritization and handling of threats. Establishing IT security insight into an operational ATM system would provide great improvements.

Encrypted Network Traffic Analysis

Looking at the future of ATM, communication will be either handled by encrypted protocols or over transparently encrypted channels. While these efforts will reduce operational insight, they still provide enough valuable data to be used for network traffic analysis. Examples of remaining data from TLS 1.3 based communication was presented by Peter Manev and Eric Leblond during Pass the SALT 2020[6].

- TLS data
 - JA3
 - JA3S
 - TLS Server Name Indication
- Flow information
 - In/out packet volume and count
 - Application layer identification
 - Tunnel information

These examples highlight, that fingerprinting of operational components based on network traffic analysis will not become obsolete and will still be a pillar of security monitoring enabling delivery of meaningful detection results.

Supporting ATN/IPS (ICAO)

The ICAO 9896 Manual on the Aeronautical Telecommunication Network (ATN) using Internet Protocol Suite (IPS) Standards and Protocol is addressing the security requirements for communications in ATN/IPS. Currently the 3rd

edition is being developed with updates related to Security.

All ATN/IPS nodes are required to implement Internet protocol security (IPsec) and the Internet key exchange 2 (IKEv2) protocol but the actual use of these provisions is to be based on a system threat and vulnerability analysis. The proposed approach is two-way mutual authentication, data integrity and privacy. ESP encryption is optional, but authentication should be always performed. IPSec and application level TLS are optional. If encryption is to be used this will be a challenge for anomaly detection systems that will only be seeing encrypted traffic limiting the scope of parameters to be used for the detection. However certain portions of the TLS traffic can be monitored to detect anomalies. Suricata can decode the TLS message, extract information and output to a JSON event. Alerting can be done on fields via dedicated keywords and the certificate chain can be extracted. JA3 algorithm can identify the client by its implementation and JA3S algorithm can identify the server. JA3 algorithm:

- Client sends TLS Client Hello after TCP session established. Packet and the way in which it is generated is dependent on packages and methods used when building the client application
- Server responds with TLS Server Hello. Similar to client, respond depends on how software was built and data sent from client
- JA3S algorithm
- Method of creating a fingerprint from the server side of the TLS handshake – TLS Server Hello
- Decimal values of the bytes for the following fields: Version, Accepted Cipher, and List of Extensions
- Concatenated and delimited as JA3
- Negotiations are sent in the clear and allow for fingerprinting. Still compatible with TLS 1.3

The Role of Software Defined Networking

Software Defined Networking (SDN) solutions are becoming more prevalent in the ATM industry.

As more and more ATM agencies and ANSPs are migrating into a more IT-based world SDN provides significant advantages over legacy networks. This allows deep insight into the network traffic and fine granular control. Architectures as described in “HIERARCHICAL SOFTWARE DEFINED NETWORKS FOR WIDE-AREA AIR TRAFFIC MANAGEMENT NETWORKS”[10] are applied to make use of the extended security functionality.

Improved network profiling (baselining) derived from SDN features and a playbook like approach to trigger reaction will be analyzed in future work.

Conclusion

In this paper we have discussed a novel approach to creating an ATM-grade baseline integrating operational security events (OSE) and alerts (OSA) based on abnormal or malicious network traffic. An assured and trusted baseline is key to detecting atypical or malicious traffic.

Given the general availability and overall maturity of the used network monitoring solutions, the technology can be regarded as proven and ready for implementation. The additional benefit of passive, unintrusive data and traffic collection makes it a prime candidate for an ANSPs security monitoring strategy. This safety aligned approach can be further regarded as one of the main building blocks for threat detection in current and future ATM systems.

An experimental setup was described where the primary notions of this design was demonstrated and tested.

Our recommendation for future project and activities in ATM is to put similar emphasis on the Detection over a Protection-only approach. The authors also recommend the consideration on RTCA/EUROCAE platform to ensure a globally coordinated approach.

Future work will involve Artificial intelligence and Machine Learning. Such approaches are described in papers like “A machine learning approach to detecting malware in TLS traffic using resilient network features[8]” or “Graph Convolutional Network-based Suspicious Communication Pair Estimation for Industrial Control Systems[9]” Follow up project could analyze applicability in ATM systems.

References

- [1] SANS CIS Critical Security Controls: Guidelines. URL [SANS Institute - CIS Critical Security Controls: Guidelines](https://www.sans.org/cis-critical-security-controls/)
- [2] MITRE. ATT&CK T1595 Active Scanning, . URL <https://attack.mitre.org/techniques/T1595/>. Accessed: 2021.03.04
- [3] MITRE. ATT&CK T1110 Brute Force, . URL <https://attack.mitre.org/techniques/T1110/>. Accessed: 2021.03.04
- [4] Shostack Adam. The Jenga View of Threat Modeling, page 5. URL https://associates.shostack.org/The_Jenga_View_of_Threat_Modeling.pdf
- [5] Shostack Adam. Threat Modeling Lessons from Star Wars, Minute 7:30. IT-SECX Conference, Austria, 2019. URL <https://youtu.be/nd02oPnMdR4?t=450>
- [6] Manev Peter and Leblond Eric. Hunting Threats That Use Encrypted Network Traffic, page 18. Pass the SALT Conference, 2020. URL <https://2020.pass-the-salt.org/files/slides/PTS2020-Talk-08-Suricata-TLS.pdf>
- [7] McCammon Keith. Prioritizing Data Sources for Minimum Viable Detection, pages 22-25. MITRE ATT&CKcon 2.0, 2020. URL <https://www.slideshare.net/attackcon2018/mitre-attckcon-20-prioritizing-data-sources-for-minimum-viable-detection-keith-mccammon-red-canary-193703088>
- [8] Jenseg Odin. A Machine Learning Approach to Detecting Malware in TLS Traffic Using Resilient Network Features, . URL <https://ntnuopen.ntnu.no/ntnu-xmlui/bitstream/handle/11250/2617735/no.ntnu%3AInnspera%3A2455409.pdf>
- [9] Oba Tatsumi and Taniguchi Tadahiro. Graph Convolutional Network-based Suspicious Communication Pair Estimation for Industrial Control Systems, . URL <https://arxiv.org/pdf/2007.10204.pdf>
- [10] J.Izquierdo-Zaragoza, W.Lins, P.Leydold, F.d’Humières, D.Eier. Hierarchical Software Defined Networks for Wide-Area Air Traffic Management NetwoRKS, ICNS

2019, URL

<https://ieeexplore.ieee.org/document/8735142>

[11] EUROCAE WG-67, 2009. Voice over the Internet Protocol (VoIP) Air Traffic Management (ATM) System Operational and Technical Requirements, ED-136, Eurocae

[12] ET OPEN Ruleset 2019. Emerging Threats Rules; URL: <https://rules.emergingthreats.net/>

Acknowledgements

The work related to ATN/IPS integration is based on the Project 14.2.4 of the SESAR2020 Joint Undertaking under the European Union's Horizon 2020 Research and Innovation program.

*2021 Integrated Communications Navigation
and Surveillance (ICNS) Conference
April 20-22, 2021*